

ZKOO: DATA PROTECTION IN DE CLOUD

ADVIESRAPPORT

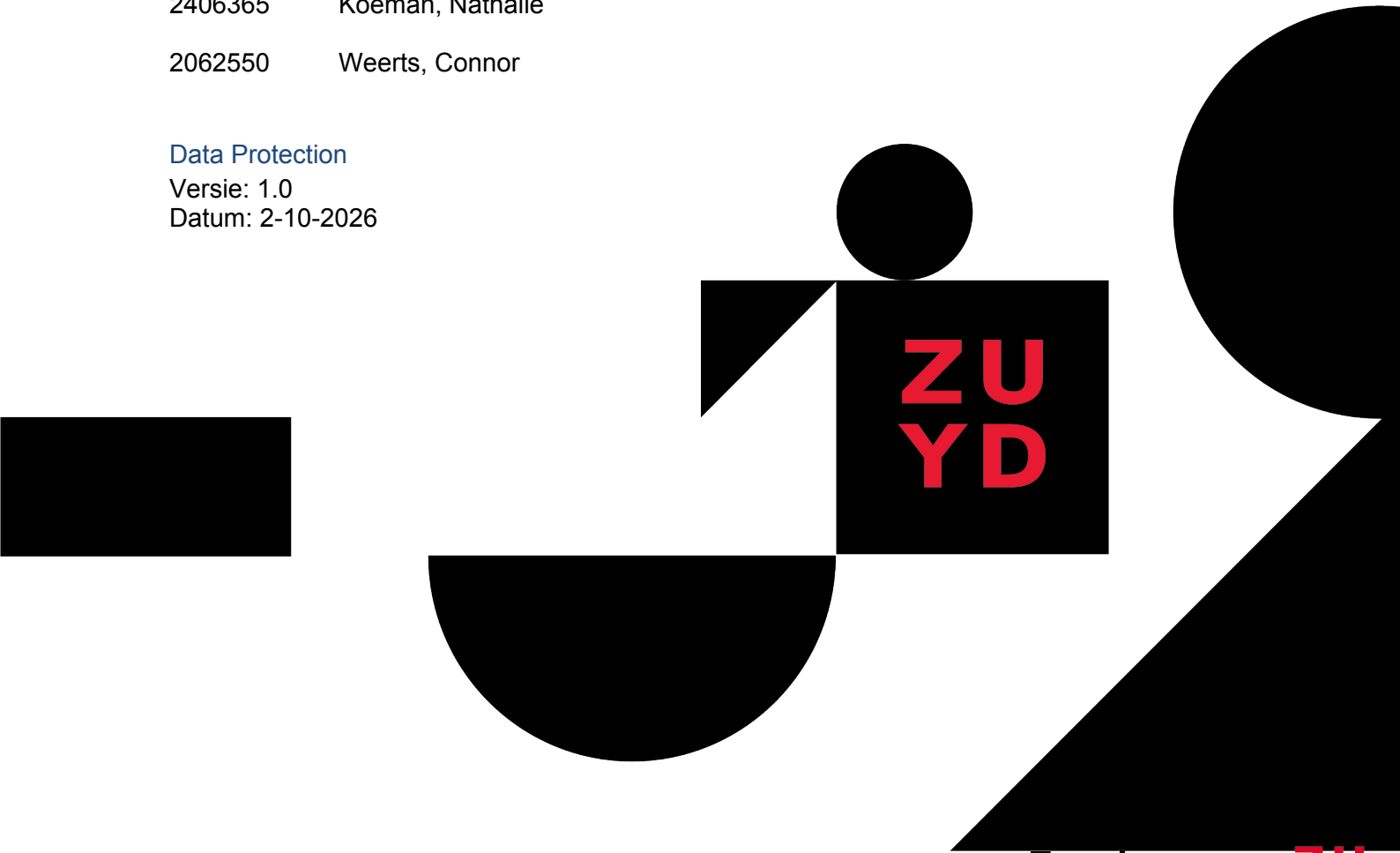
ZKOO3

Auteurs

2505493	Arman, Maiwand
2605402	Carley, Chris
2406365	Koeman, Nathalie
2062550	Weerts, Connor

Data Protection

Versie: 1.0
Datum: 2-10-2026



ZU
YD

Managementsamenvatting

ZKOO verwerkt gevoelige medische gegevens in de cloud. Uit onze analyse blijkt dat de huidige beveiliging onvoldoende is ingericht. Systemen zijn onvoldoende van elkaar afgeschermd, toegangsrechten zijn te ruim en er is onvoldoende controle op verdachte activiteiten.

De belangrijkste risico's zijn dat medische gegevens uitlekken, onbevoegden toegang krijgen en kwetsbaarheden in applicaties worden misbruikt.

Wij adviseren ZKOO om de beveiliging te verbeteren door systemen beter van elkaar te scheiden, toegang beter te controleren, medische gegevens extra te beschermen en activiteiten beter te monitoren. Hiermee wordt de kans op beveiligingsincidenten verkleind en wordt de bescherming van medische gegevens verbeterd.

Inhoud

1. Inleiding.....	1
2. Beschrijving van de huidige situatie (IST).....	3
Analyse van de huidige situatie (IST).....	3
Risicoanalyse	5
3. Verbetervoorstellen (SOLL)	6
Beveiligingsstrategie	6
4. Ontwerp.....	10
IPplan	10
Naamconventie	10
Security framework.....	10
Visuele weergave.....	11
5. Conclusie en aanbeveling.....	12
Conclusie.....	12
Aanbevelingen aan ZKOO	12
Literatuurlijst.....	14
Bijlagen	15
Bijlage A: IST-diagram	15
Bijlage B: SOLL-Diagram	16

1. Inleiding

Dit hoofdstuk beschrijft de aanleiding, het doel en de scope van het onderzoek. Daarnaast worden de onderzoeksvraag, de aanpak en het juridische en technische kader toegelicht.

Opdrachtgever ZKOO (Zorg Kwaliteit Ondersteuningsorganisatie) ondersteunt zorginstellingen die medische data verwerken in hun software. De opdrachtgever is door een versneld traject naar Microsoft Azure overgestapt. De focus lag voornamelijk bij beschikbaarheid en functionaliteit, terwijl beveiliging minder aandacht heeft gekregen. Hierdoor zijn kritieke componenten onvoldoende beveiligd. Een databeveiligingsbeleid ontbreekt, toegangscontroles zijn niet duidelijk ingericht en de AVG-wet wordt mogelijk geschonden.

Dit rapport dient ervoor om de beveiligingsrisico's inzichtelijk te maken en advies te geven over mogelijke verbeteringspunten. Het onderzoek beperkt zich tot de gesimuleerde cloudomgeving in Microsoft Azure. De fysieke systemen van ZKOO worden hierbij buiten beschouwing gelaten.

Het team gaat aan de slag met de vraag: "Hoe kan ZKOO de gegevensbescherming in haar cloudomgeving structureel verbeteren?". Het antwoord hierop proberen wij te vinden door gebruik te maken van de volgende onderzoeksmethoden:

IST-analyse Met een IST-analyse brengen we de huidige inrichting van de Azure omgeving in kaart. Hierbij wordt gekeken naar de netwerkstructuur, het toegangsbeheer, monitoring en de beveiliging van de applicaties.

Risicoanalyse Met een risicoanalyse onderzoeken we welke beveiligingsrisico's aanwezig zijn. We beoordelen de risico's op hoe waarschijnlijk het is dat het risico optreedt en welke gevolgen dit kan hebben.

Na het analyseren van de huidige situatie en de risico's van de bestaande infrastructuur, ontwerpt het team een passende oplossing. Vervolgens wordt een conclusie getrokken en worden er passende aanbevelingen gedaan aan ZKOO.

In het juridische kader moeten we rekening houden met de AVG-wet, en normen NEN7510 en ISO27001. Deze wet en normen worden hieronder kort toegelicht:

AVG De Europese privacywet die regels stelt aan het verwerken van persoonsgegevens (Autoriteit Persoonsgegevens, sd).

NEN-7510 Een Nederlandse norm voor informatiebeveiliging in de zorg. De norm beschrijft hoe organisaties de vertrouwelijkheid, integriteit en beschikbaarheid van de informatie moeten beschermen (NEN, sd).

ISO27001 Een internationale norm voor het organiseren en verbeteren van informatiebeveiliging (ISO, sd).

Om het rapport zo begrijpelijk mogelijk te maken, volgt hier een korte begrippenlijst waarin de belangrijkste begrippen uit dit rapport kort worden uitgelegd:

Dataclassificatie	Gegevens indelen op basis van hun gevoeligheid en de bescherming die zij nodig hebben.
Persoonsgegevens	Gegevens waarmee iemand kan worden geïdentificeerd.
Beveiligingslek	Een zwakke plek in de beveiling die kan worden misbruikt.
Toegangsbeheer	Bepalen wie toegang heeft tot welke systemen en gegevens en welke handelingen die persoon mag uitvoeren.
Encryptie	Het versleutelen van gegevens, zodat deze zonder de juiste sleutel niet leesbaar zijn.

Het juridische kader is van belang voor ZKOO, omdat ZKOO medische gegevens verwerkt. Een goede bescherming van deze gegevens is dan erg belangrijk. Binnen dit onderzoek gebruiken wij daarom de wet en normen als kader om de huidige beveiliging te beoordelen en onze verbeteringen te kunnen onderbouwen.

2. Beschrijving van de huidige situatie (IST)

In dit hoofdstuk beschrijven we de huidige situatie (IST) van de IT-omgeving van ZKOO, zoals deze is opgebouwd tijdens de analysefase. Deze omgeving is gebaseerd op Microsoft Azure, omdat ZKOO bewust kiest voor een cloud platform dat flexibel kan opschalen en aansluit bij de bestaande applicaties en databases van de organisatie. De IST-omgeving bestaat uit een aantal virtuele machines, een SQL Database en een aparte opslaglocatie voor gevoelige medische bestanden. Deze systemen draaien op een netwerk dat volgens het principe 'Allow Everything' is ingericht, wat betekent dat systemen onderling vrijwel onbeperkt met elkaar kunnen communiceren. In dit hoofdstuk lichten we per component de functie, de beveiligingsmaatregelen (of het gebrek daaraan) en de bijbehorende risico's toe. De resultaten van deze analyse vormen de basis voor de risicoanalyse en het SOLL-ontwerp in de volgende hoofdstukken.

Analyse van de huidige situatie (IST)

Het volledige IST-diagram is te vinden in bijlage A: IST-diagram.

Inventarisatie van huidige inrichting:

Netwerkstructuur

De omgeving van ZKOO draait in Microsoft Azure. Het IST-diagram toont het virtuele netwerk met het adresbereik 192.168.0.0/16. Binnen de omgeving zijn onder andere webserver, een applicatieserver, een fileserver en databases aanwezig. Het patiëntportaal op VM-WEB01 communiceert rechtstreeks met de MySQL-database op VM-DB01. Daarnaast gebruikt ZKOO een Azure SQL Database voor nieuwe functionaliteiten en een aparte opslaglocatie voor gevoelige medische bestanden.

Het netwerk is ingericht volgens het "Allow Everything" principe. Dit betekent dat systemen onderling vrijwel onbeperkt kunnen communiceren. Hierdoor zijn publieke en interne systemen en beheerfuncties onvoldoende van elkaar gescheiden.

Toegangsbeheer

Binnen de casus worden gebruikers, medewerkers en systeembeheerders onderscheiden omdat zij verschillende toegangsbehoeften hebben. Zorgverleners moeten toegang hebben tot het patiëntportaal, terwijl systeembeheerders de omgeving moeten kunnen beheren. De toegangscontrole is echter onvoldoende ingericht.

Logging & monitoring

Binnen de omgeving is VM-IDS01 aanwezig. Op deze server draait een Intrusion Detection System (IDS), dat netwerkverkeer controleert op verdachte activiteiten en bekende aanvalspatronen. Tijdens het onderzoek wordt gecontroleerd of het IDS actief is en welke meldingen het genereert.

Softwarekwaliteit

ZKOO gebruikt zowel bestaande als nieuwe applicaties. Het intern ontwikkelde patiëntportaal op VM-WEB01 verwerkt medische gegevens en maakt gebruik van de MySQL-database. Daarnaast is WebAPP02 aanwezig als nieuwe internetgerichte cloudapplicatie. Er zijn aanwijzingen dat de webapplicaties kwetsbaar zijn voor SQL Injection en Cross-Site Scripting (XSS). Bij WebAPP02 ontbreekt aanvullende bescherming tegen deze aanvallen.

Geconstateerde zwakke plekken:

Onvoldoende toegangscontrole

De toegang tot systemen en gegevens is onvoldoende beperkt. Hierdoor bestaat het risico dat gebruikers toegang krijgen tot medische gegevens waarvoor zij geen toestemming hebben.

Geen segmentatie

Het netwerk is onvoldoende opgedeeld in subnetten. Door de 'Allow Everything'-inrichting kan een aanvaller die één systeem binnendringt mogelijk ook andere systemen bereiken.

Kwetsbare code

Er zijn aanwijzingen voor SQL Injection en XSS (cross site scripting) in de webapplicaties. Bij SQL Injection kan een aanvaller mogelijk toegang krijgen tot data waar het niet voor bevoegd is. Bij XSS kan ongewenste scriptcode worden uitgevoerd in de browser van een gebruiker. De aanwezigheid en gevolgen van deze kwetsbaarheden moeten nog met testen worden bevestigd.

Ontbrekende of ineffectieve monitoring

Er is een IDS aanwezig, maar het is nog niet vastgesteld of dit voldoende netwerkverkeer controleert en of meldingen worden opgevolgd. Hierdoor bestaat het risico dat verdachte activiteiten niet of te laat worden opgemerkt.

Risicoanalyse

Risico	Impact	Kans	Beheersmaatregel	Urgentie
Datalek medische gegevens	Zeer hoog	Hoog	Encryptie en toegangscontrole	Kritiek
Onbevoegde toegang	Zeer hoog	Hoog	MFA en least privilege	Kritiek
SQL Injection	Zeer hoog	Hoog	Inputvalidatie en WAF	Kritiek
XSS	Hoog	Hoog	Inputvalidatie en output encoding	Hoog
Slechte netwerksegmentatie	Zeer hoog	Hoog	NSG's en firewall	Kritiek
Onvoldoende logging/IDS	Hoog	Hoog	Centrale logging en monitoring	Hoog
Publieke toegang interne systemen	Zeer hoog	Middel	Private endpoints en VPN/Bastion	Kritiek
Verouderde software	Hoog	Hoog	Patchmanagement	Hoog
Te ruime database-rechten	Zeer hoog	Middel	Least privilege en RBAC	Hoog
Onveilige bestandsoverdracht	Hoog	Middel	Encryptie en toegangscontrole	Hoog

OWASP-koppeling

- SQL Injection → **Injection**
- XSS → **Injection**
- Onbevoegde toegang → **Broken Access Control**
- Onveilige configuratie → **Security Misconfiguration**
- Onvoldoende logging → **Security Logging & Alerting Failures**

3. Verbetervoorstellen (SOLL)

In dit hoofdstuk worden de verbetervoorstellen voor de Azure omgeving van ZKOO beschreven. Deze zijn gebaseerd op de resultaten van de IST analyse en de risicoanalyse. Het doel is om de algemene technische bescherming en de bescherming van medische gegevens te verbeteren.

Beveiligingsstrategie

De beveiligingsstrategie is gebaseerd op Defense in Depth. Dit betekent dat er meerdere lagen in beveiliging worden toegepast. Wanneer één maatregel faalt, helpen andere maatregelen om de gevolgen hiervan te beperken.

Topologie en netwerkarchitectuur

Het huidige netwerk gebruikt het Allow Everything-principe, waardoor systemen vrijwel onbeperkt met elkaar kunnen communiceren. Wij stellen voor om het netwerk op te delen in vijf subnetten: het DMZ-subnet, interne subnet, database-subnet, beheer-subnet en monitoring-subnet. De reden voor deze vijf subnetten is dat ieder subnet een eigen functie en beveiligingsniveau heeft. Hierdoor kan gericht worden bepaald welk verkeer wel en niet is toegestaan.

Internetgerichte systemen worden in de DMZ geplaatst. Elk subnet krijgt een eigen Network Security Group (NSG) met een *default deny*-beleid. Dit betekent dat verkeer standaard wordt geblokkeerd en alleen expliciet toegestaan verkeer wordt doorgelaten.

Hierdoor wordt het netwerk beter gescheiden en kan een aanvaller zich na het binnendringen van één systeem minder gemakkelijk naar andere systemen verplaatsen. Dit vormt een belangrijke beveiligingslaag binnen Defense in Depth.

De vijf subnetten worden gerealiseerd zoals beschreven in het IP-plan:

- **Subnet 10 – DMZ (10.10.10.0/24):** ZKOO-WEB-02, WebAPP02 en ZKOO-FTP-01.
- **Subnet 20 – Intern (10.10.20.0/24):** ZKOO-WEB-01 en ZKOO-APP-01.
- **Subnet 30 – Database (10.10.30.0/24):** ZKOO-DB-01 en File server.
- **Subnet 40 – Beheer (10.10.40.0/24):** beheersystemen.
- **Subnet 50 – Monitoring (10.10.50.0/24):** IDS en monitoring.

Elk subnet krijgt een eigen NSG met een *default deny*-beleid. Alleen noodzakelijke poorten en bronadressen worden toegestaan. Zo mag het database-subnet alleen noodzakelijk verkeer vanuit het interne subnet ontvangen en accepteert het DMZ-subnet alleen noodzakelijk internetverkeer, zoals HTTPS naar de internetgerichte webapplicaties.

Toegangsbeheer

Het toegangsbeheer wordt verbeterd door Role-Based Access Control (RBAC), Multi-Factor Authentication (MFA) en een Zero Trust Policy toe te passen. Voor MFA wordt Microsoft Authenticator gebruikt. Gebruikers krijgen standaard zo min mogelijk rechten en alleen extra rechten wanneer deze noodzakelijk zijn voor hun werkzaamheden. Met RBAC worden deze rechten gekoppeld aan de functie van de gebruiker.

MFA zorgt voor een extra verificatiestap bij het aanmelden. Met Zero Trust wordt iedere toegang gecontroleerd en wordt een gebruiker niet automatisch vertrouwd omdat deze zich binnen het netwerk bevindt.

Deze maatregelen vormen de Identity and Access security binnen Defense in Depth en beperken het risico op ongeautoriseerde toegang.

Voor identiteitsbeheer wordt Azure Active Directory gebruikt. RBAC wordt ingericht met rollen die aansluiten op de gebruikersrollen uit de casus (User, Employee, Admin), zodat elke rol alleen toegang krijgt tot de systemen en gegevens die voor die functie noodzakelijk zijn. MFA wordt afgedwongen via een Conditional Access-policy die bij elke aanmelding een extra verificatiestap vereist. De Zero Trust Policy wordt technisch vertaald naar Conditional Access-regels die bij iedere toegangsaanvraag opnieuw controleren of de gebruiker en het apparaat aan de voorwaarden voldoen, ongeacht of de aanvraag van binnen of buiten het netwerk komt.

Data security

Medische gegevens worden aangemerkt als gevoelige data en krijgen extra bescherming. We gaan de data encrypten tijdens transport en bij opslag. Daarnaast wordt de toegang tot de gegevens beperkt met RBAC en het least-privilege-principe.

Dit vormt de Data Protection layer binnen Defense in Depth en beschermt medische gegevens tegen ongeautoriseerde toegang.

Voor de Azure SQL Database wordt Transparent Data Encryption gebruikt voor encryptie van data at rest. Voor ZKOO-DB-01 wordt de virtuele schijf versleuteld met Azure Disk Encryption en wordt de database geconfigureerd om verbindingen alleen via TLS te accepteren, zodat medische gegevens ook tijdens transport versleuteld zijn. De toegang tot deze gegevens wordt, in lijn met het toegangsbeheer, beperkt met RBAC en het least-privilege-principe, zodat alleen geautoriseerde rollen bij de medische gegevens kunnen.

Applicatiebeveiliging

De mogelijke kwetsbaarheden voor XSS en SQL Injection worden aangepakt door inputvalidatie, veilige programmeertechnieken en code reviews. Daarnaast wordt voor de internetgerichte webapplicaties een Web Application Firewall (WAF) ingezet. De WAF

controleert inkomend webverkeer en kan bekende aanvalspatronen, zoals SQL Injection en XSS, detecteren en blokkeren.

Tijdens code reviews wordt gecontroleerd op beveiligingsproblemen en onveilige code. Dit vormt de Application Layer Security binnen Defense in Depth.

Inputvalidatie wordt in de applicatiecode van het patiëntportaal en WebAPP02 geïmplementeerd, onder andere met parameterized queries ter voorkoming van SQL Injection en output-encoding ter voorkoming van XSS. Code reviews worden uitgevoerd aan de hand van een vaste checklist, waarbij specifiek wordt gecontroleerd op deze twee kwetsbaarheden uit de risicoanalyse. Na het doorvoeren van de maatregelen worden de webapplicaties opnieuw getest op SQL Injection en XSS, zoals ook als Must have is opgenomen in de aanbevelingen.

Monitoring & logging

De bestaande IDS wordt gebruikt om verdachte activiteiten op het netwerk te detecteren. Hiervoor wordt Suricata ingezet op het IDS-systeem binnen het monitoring-subnet. Suricata analyseert het netwerkverkeer op bekende aanvalspatronen, zoals pogingen tot SQL-injectie of XSS richting de webapplicaties, en genereert een alert zodra een signature afgaat. Daarnaast worden verbindingsgegevens (bron, bestemming, poort, protocol en hoeveelheid data) vastgelegd, ook wanneer er geen alert wordt gegenereerd, zodat ook niet-gealarmeerd verkeer achteraf geanalyseerd kan worden.

Naast deze netwerkmonitoring worden op de systemen zelf audit trails bijgehouden. Via de Windows Security Event Log op de domain controller wordt vastgelegd wie zich heeft aangemeld en welke rechten zijn gebruikt. Op de Linux-systemen wordt auditd ingezet om bestandstoegang en configuratiewijzigingen te registreren, en op de databases wordt database-auditing ingeschakeld om vast te leggen welke query's en acties op de medische gegevens zijn uitgevoerd en door welk account. Hiermee kan, in tegenstelling tot de netwerklogging van Suricata, specifiek worden vastgesteld wie toegang heeft gehad tot een systeem of gegevensset en welke acties die persoon daar heeft uitgevoerd.

Alle loggegevens, zowel de netwerklogging vanuit Suricata als de audit trails vanuit de systemen, worden centraal verzameld in een Log Analytics Workspace. Door deze bronnen op tijdstip en IP-adres met elkaar te correleren, kan bij een beveiligingsincident het netwerkperspectief (wat er over het netwerk gebeurde) gekoppeld worden aan het identiteitsperspectief (wie dit deed), waardoor incidenten sneller en vollediger kunnen worden gedetecteerd en onderzocht.

Deze maatregelen ondersteunen meerdere beveiligingslagen binnen Defense in Depth, doordat zowel verdachte netwerkactiviteiten als ongeautoriseerde toegang binnen de omgeving kunnen worden gedetecteerd.

Beheer op afstand

Beheerders krijgen alleen via een beveiligde VPN-verbinding toegang tot de systemen. Vanuit een beheersysteem in subnet 40 (Beheer) worden de servers beheerd via SSH voor Linux of RDP voor Windows. Deze hulpmiddelen vormen de beheerinterface. Voor authenticatie via SSH wordt gebruikgemaakt van een public key en private key. Daarnaast wordt MFA toegepast bij toegang tot de beheeromgeving en krijgen beheerders via RBAC alleen de rechten die noodzakelijk zijn voor hun werkzaamheden. Het beheersubnet is niet rechtstreeks toegankelijk vanaf het openbare internet. Het beheersysteem krijgt geen publiek IP-adres.

Alle beheerdersactiviteiten worden gelogd, zodat achteraf kan worden gecontroleerd welke acties zijn uitgevoerd. Deze maatregelen vallen voornamelijk onder de Identity and access security-laag en Network security-laag binnen Defense in Depth.

4. Ontwerp

In dit hoofdstuk wordt het ontwerp voor de veiligere Azure-omgeving van ZKOO omschreven. Het ontwerp is gebaseerd op de risicoanalyse en de verbetervoorstellen uit hoofdstuk 3. Het ontwerp bestaat uit het IP-plan, de naamconventie, het security framework en het SOLL-diagram.

IPplan

Subnet	Segment	Netwerk	Gateway	Systemen
10	DMZ	10.10.10.0/24	10.10.10.1	VM-WEB02, WebAPP02, VM-FTP01
20	Intern	10.10.20.0/24	10.10.20.1	VM-WEB01, VM-APP01
30	Database	10.10.30.0/24	10.10.30.1	VM-DB01, File server
40	Beheer	10.10.40.0/24	10.10.40.1	Beheersystemen
50	Monitoring	10.10.50.0/24	10.10.50.1	IDS en monitoring

Naamconventie

Voor de Azure-omgeving van ZKOO gebruiken we een vaste naamconventie. Voor virtuele machines gebruiken we de structuur ZKOO-[functie]-[nummer]. Een voorbeeld hiervan is ZKOO-WEB-01, waarbij ZKOO de organisatie aangeeft, WEB de functie en 01 het nummer van de server.

Security framework

Voor het SOLL-ontwerp van ZKOO wordt gebruik gemaakt van de relevante onderdelen van de Microsoft Cloud Security Benchmark (MCSB) als kader (Microsoft, sd). Deze benchmark bevat richtlijnen voor het beveiligen van cloudomgevingen. Voor ons ontwerp zijn vooral netwerkbeveiliging, toegangsbeheer, gegevensbescherming en logging en monitoring van belang. Deze onderdelen sluiten aan op de uitkomst van de risicoanalyse en de verbetervoorstellen uit hoofdstuk 3.

Bij het toepassen van bovengenoemd kader staat Security by Design centraal. Dit betekent dat beveiliging vanaf het begin wordt meegenomen in het ontwerp. Voor ZKOO wordt daarom vooraf bepaald welke systemen met elkaar mogen communiceren, welke gebruikers toegang hebben en hoe medische gegevens worden beschermd.

De maatregelen uit hoofdstuk 3 zijn op basis van deze uitgangspunten verwerkt in het IP-plan en het SOLL-diagram. Tijdens de realisatiefase wordt getest of toegestane verbindingen werken, ongeautoriseerde toegang wordt geweigerd en relevante activiteiten worden gelogd. Zo vormen de beveiligingsprincipes de basis voor zowel het ontwerp als de controle ervan.

Visuele weergave

Het volledige SOLL -diagram is te vinden in bijlage B: SOLL-diagram.

5. Conclusie en aanbeveling

In dit hoofdstuk worden de belangrijkste bevindingen uit de analyse samengevat en aanbevelingen gedaan om de beveiliging van ZKOO te verbeteren. Met de MoSCoW-methode wordt aangegeven welke maatregelen de hoogste prioriteit hebben en waarom.

Conclusie

Tijdens de overstap naar Microsoft Azure heeft ZKOO vooral aandacht besteed aan beschikbaarheid en functionaliteit. De beveiliging is daarbij niet voldoende meegenomen. Uit de risicoanalyse blijkt dat systemen onvoldoende van elkaar zijn afgeschermd en dat het toegangsbeheer moet worden verbeterd. Daarnaast zijn er aanwijzingen voor kwetsbaarheden in de webapplicaties en is het niet duidelijk of verdachte activiteiten op tijd worden opgemerkt en opgevolgd. Hierdoor bestaat de kans dat onbevoegden toegang hebben tot medische gegevens.

ZKOO kan de gegevensbescherming verbeteren door netwerksegmentatie, beperkte toegangsrechten, encryptie, applicatiebeveiliging en monitoring gezamenlijk toe te passen. Deze maatregelen ondersteunen de bescherming van persoonsgegevens zoals bedoeld in de AVG en sluiten aan bij de beveiligingsdoelen van NEN 7510 en ISO 27001. Het ontwerp alleen toont echter nog niet aan dat ZKOO volledig aan deze eisen voldoet.

Het SOLL-ontwerp vormt de basis voor de realisatie. Tijdens deze fase moet met beveiligingstesten worden vastgesteld of de maatregelen daadwerkelijk werken. Daarbij wordt gecontroleerd of noodzakelijke verbindingen beschikbaar blijven, ongeautoriseerde toegang wordt geweigerd en relevante activiteiten worden gelogd.

Aanbevelingen aan ZKOO

De aanbevelingen zijn geprioriteerd met de MoSCoW-methode. Hierbij wordt onderscheid gemaakt tussen noodzakelijke maatregelen (Must have), belangrijke aanvullingen (Should have), optionele verbeteringen (Could have) en onderdelen die niet binnen de Proof of Concept (PoC) worden uitgevoerd (Won't have this time).

Must have

Deze maatregelen hebben de hoogste prioriteit, omdat deze de belangrijkste risico's beperken:

- Richt de vijf subnetten in en sta alleen noodzakelijk netwerkverkeer toe.
- Beperk toegangsrechten met RBAC en pas MFA en een beveiligde beheerverbinding toe voor beheerders.
- Versleutel medische gegevens tijdens transport en bij opslag.
- Test de webapplicaties op SQL-injection en XSS, herstel gevonden kwetsbaarheden en test opnieuw.
- Richt Suricata en logging in en leg vast wie meldingen opvolgt.

Should have

Deze maatregelen ondersteunen het onderhoud van de beveiliging en de opvolging van incidenten:

- Maak afspraken over updates en regelmatige controle van toegangsrechten en netwerkregels.
- Verzamel belangrijke loggegevens centraal.
- Leg vast hoe beveiligingsincidenten worden onderzocht en afgehandeld.

Could have

Deze verbeteringen kunnen worden uitgevoerd wanneer voldoende tijd en middelen beschikbaar zijn:

- Voeg een dashboard toe voor een overzicht van beveiligingsmeldingen.
- Stel aanvullende automatische waarschuwingen in.
- Automatiseer beveiligingstesten waar mogelijk.

Won't have (this time)

De volledige invoering van het ontwerp in een productieomgeving valt buiten deze PoC. Binnen de opdracht worden de beveiligingsmaatregelen in de gesimuleerde Azure-omgeving gerealiseerd en getest.

Literatuurlijst

Autoriteit Persoonsgegevens. (sd). *De AVG in het kort*. Opgehaald van Autoriteit Persoonsgegevens: <https://www.autoriteitpersoonsgegevens.nl/themas/basis-avg/avg-algemeen/de-avg-in-het-kort>

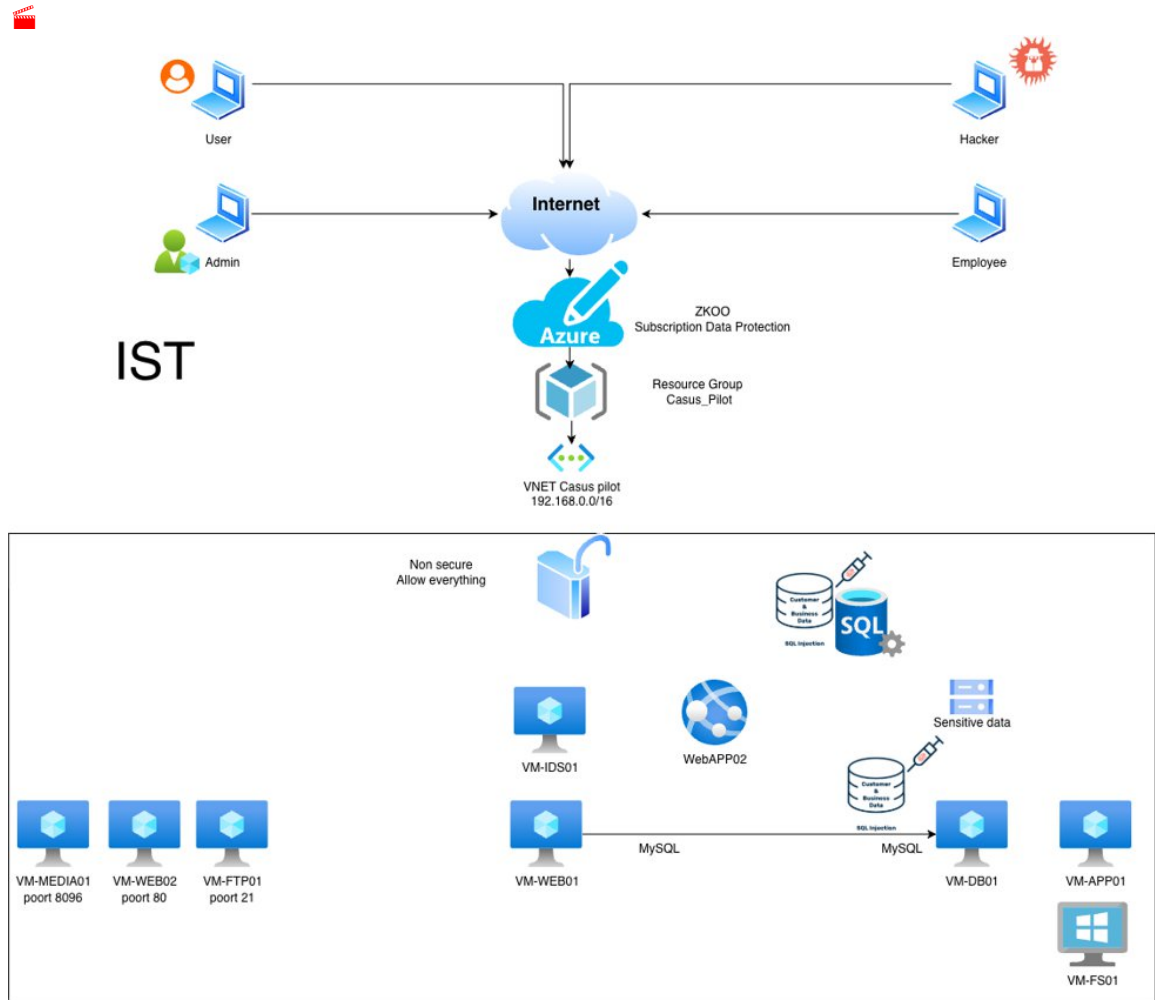
ISO. (sd). *ISO/IEC 27001:2022*. Opgehaald van ISO: <https://www.iso.org/standard/27001>

Microsoft . (sd). *Overview of Microsoft cloud security benchmark (v1)*. Opgehaald van Microsoft Learn: <https://learn.microsoft.com/en-us/security/benchmark/azure/overview-mcsb-v1>

NEN. (sd). *NEN 7510: Informatiebeveiliging in de zorg*. Opgehaald van Alles over NEN 7510: <https://www.nen.nl/zorg-welzijn/ict-in-de-zorg/informatiebeveiliging-in-de-zorg>

Bijlagen

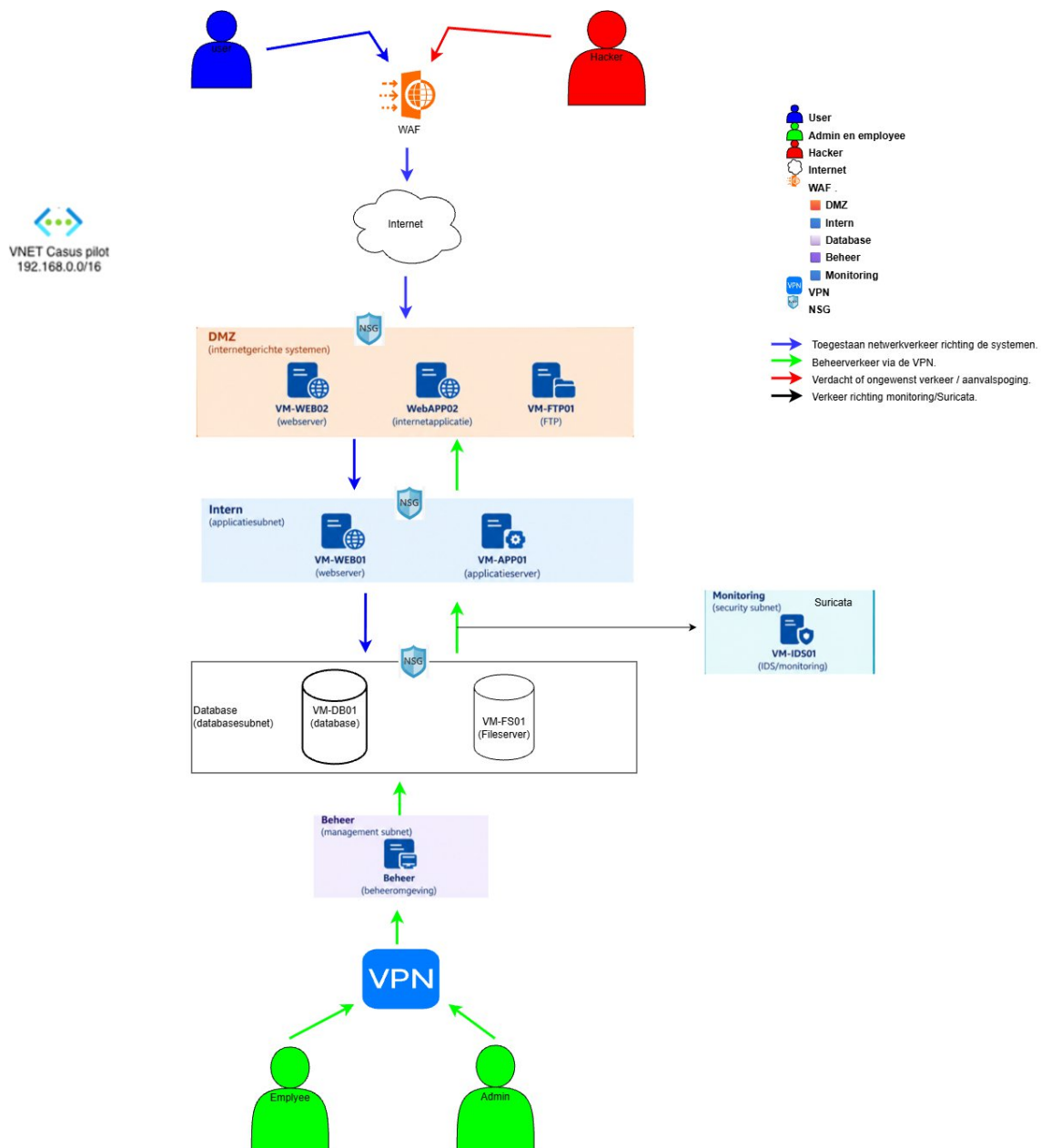
Bijlage A: IST-diagram



Figuur 1: IST-diagram ZKOO

- User** Een zorgverlener of medewerker van een aangesloten zorginstelling die gebruikmaakt van de applicaties van ZKOO.
- Employee** Een medewerker van ZKOO die toegang heeft tot interne systemen.
- Admin** Een systeembeheerder die verantwoordelijk is voor het beheer van de omgeving.
- Hacker** Een externe aanvalleur die probeert ongeautoriseerde toegang te verkrijgen tot systemen of gevoelige gegevens.

Bijlage B: SOLL-Diagram



Figuur 2: SOLL-diagram ZKOO

Binnen ZKOO worden drie gebruikersrollen onderscheiden:

User Een zorgverlener die via het patiëntportaal alleen de patiëntgegevens mag bekijken en bewerken waarvoor deze bevoegd is.

Employee Een medewerker van ZKOO die alleen toegang krijgt tot de interne applicaties en bestanden die nodig zijn voor de eigen werkzaamheden.

Admin Een systeembeheerder die systemen configureert, accounts en rechten beheert en beveiligingslogs bekijkt.

Hierbij geldt het least privilege-principe: iedere gebruiker krijgt alleen de noodzakelijke rechten. Een beheerder krijgt vanuit deze rol niet automatisch toestemming om medische gegevens inhoudelijke te bekijken.